One Page to Rule Them All

Hijacking MCP Servers Using DNS Rebinding

Avishai Gonen · Yotam Perkal

PLUTO

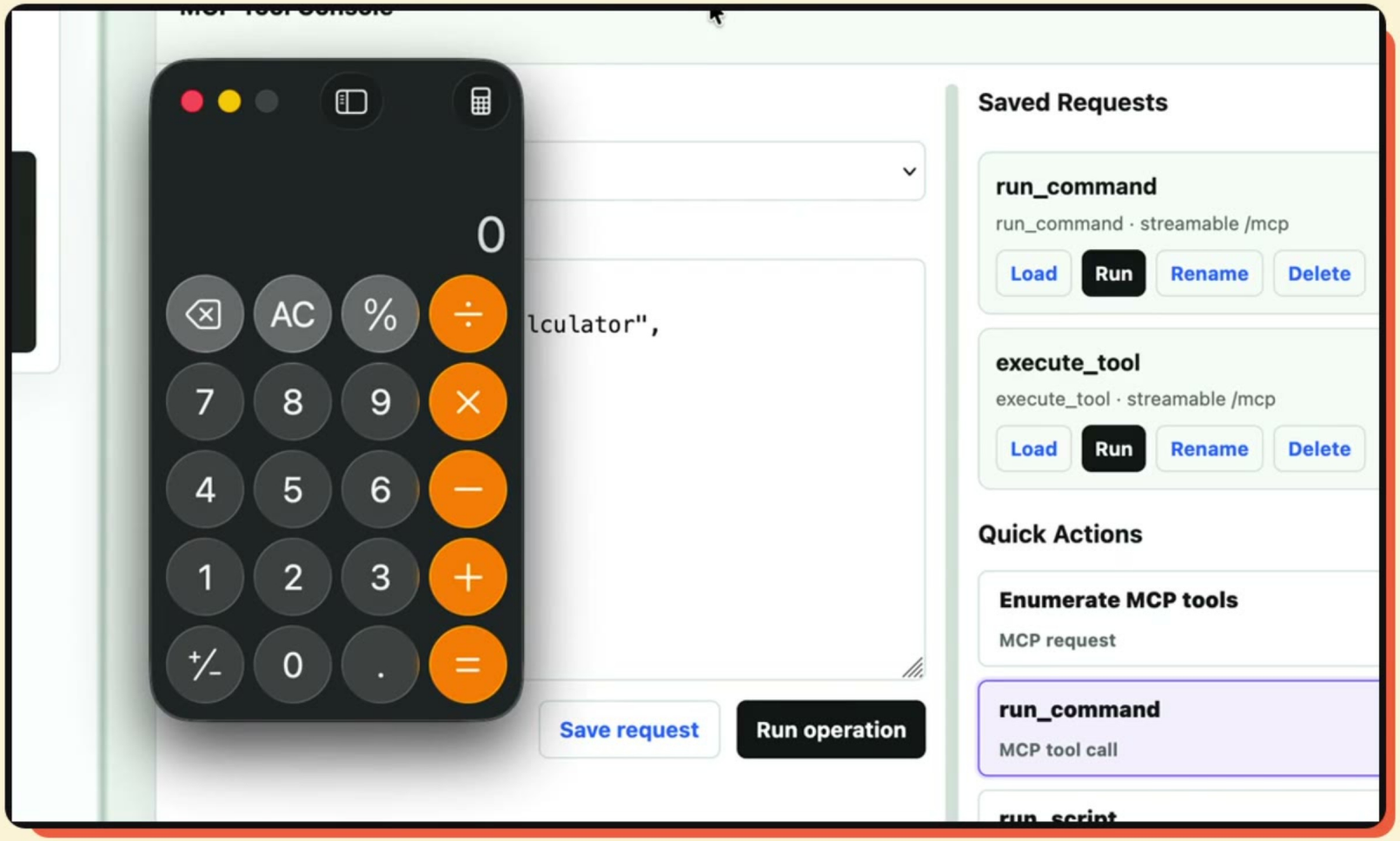
WHAT WE KEPT HEARING

...this has been marked as **Not Applicable**.

Although the scenario described may be theoretically possible, it does not represent a realistic or impactful attack under practical, real-world conditions.

Bug bounty triage

Replies to our DNS rebinding reports. Informative. Not Applicable. Risk is deemed tolerable.



Developer's laptop Step 6 of 6

Calculator opens on the developer's Mac.

> The page never touched the machine. The MCP server did it for them.

UI-TARS desktop · ~40K stars

Fork 4k Star 39.6k

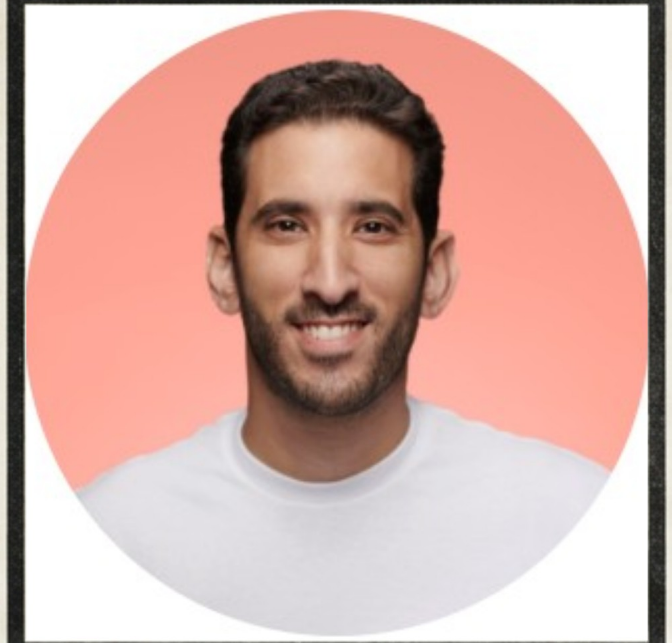
An open-source multimodal AI agent stack: a desktop agent that sees your screen and drives your computer.

CVE-2026-81735

Pluto Security · UI-TARS desktop

Avishai Gonen

Vulnerability researcher at Pluto Security. CTFs, bug bounty and independent research. 30+ CVEs.



Yotam Perkal

Leads security research at Pluto Security. Previously Threat Research at Zscaler, Vulnerability Research at Rezilion, security roles at PayPal. Active in AI-security and supply-chain working groups.

Down, down, down. Would the fall never come to an end?

...Alice had begun to think that very few things indeed were really impossible.

Lewis Carroll, *Alice's Adventures in Wonderland*, 1865

50+

CVEs and advisories · one bug class

Microsoft · **CircleCI** · **JFrog** · **MongoDB** · **Elasticsearch** · **Grafana** and many more

MCP

Model Context Protocol

The standard way AI agents reach your tools, files and APIs.

Many MCP servers run on your own laptop, and listen on **localhost**.

stdio

The client starts the server as a child process and talks over stdin and stdout.
No network port. A browser cannot reach it.

Streamable HTTP / SSE

The server listens on a port, like http://localhost:8000/mcp, and takes JSON-RPC over POST.
Anything that can send HTTP to that port can talk to it.

Localhost is a tiny door. Authors assume only local apps can fit through it.

It's on localhost, so only local apps can reach it.

DNS rebinding

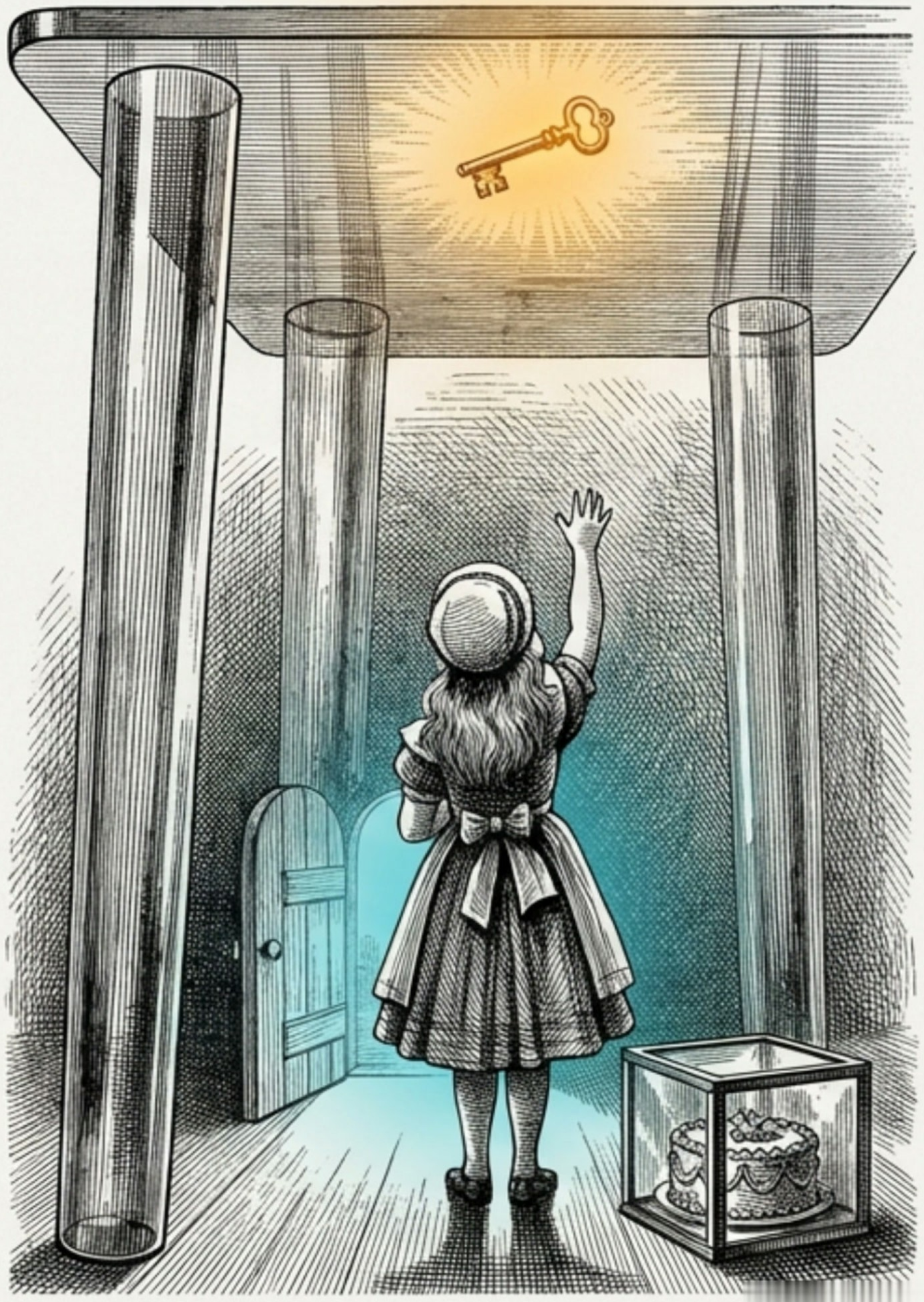
Nothing that breaks this assumption is new.

Small enough for the door. The key was out of reach.

Chrome asks the user	A rebound page triggers the Local Network Access prompt	✗
Extension with host permissions	Exempt from the prompt, reaches localhost with no prompt at all	✓

Chrome 142 · Edge 143 · Firefox 153 ask · Brave blocks

Safari has no loopback check · Extensions are exempt

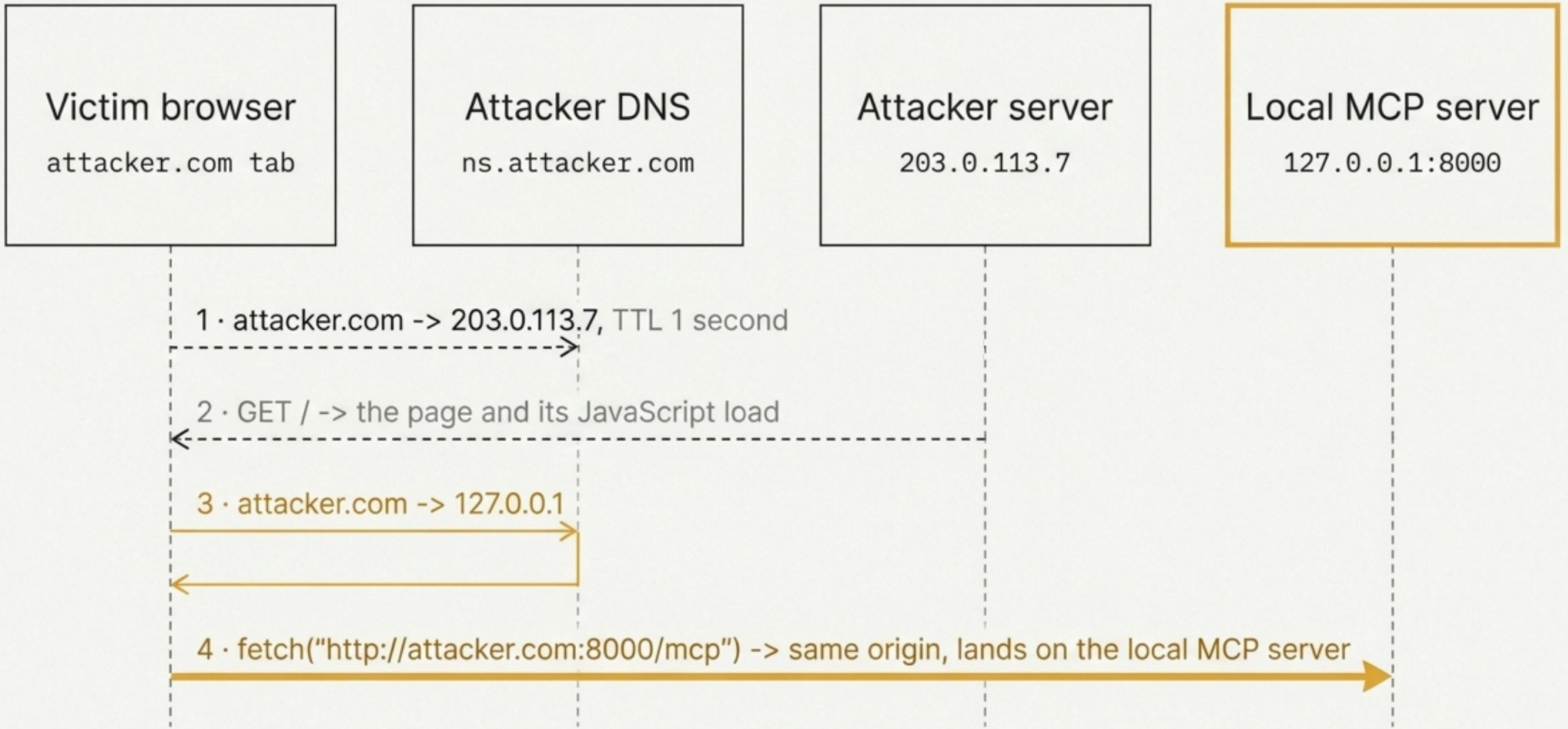


Who are you?

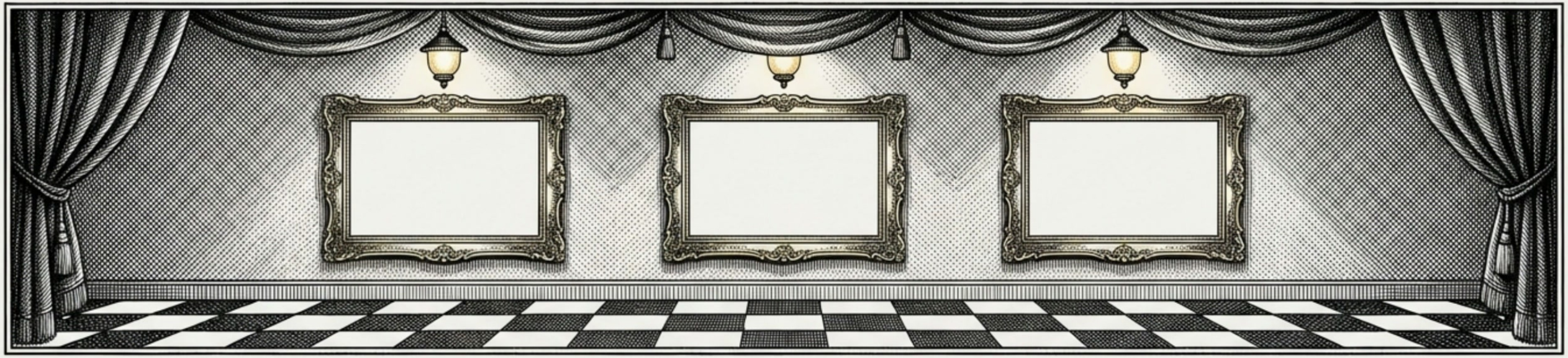
At least I know who I was when I got up this morning, but I think I must have been changed several times since then.

Alice, to the Caterpillar

```
attacker.com, a minute ago -> 203.0.113.7
attacker.com, now -> 127.0.0.1
```



The browser trusts the hostname, not the IP behind it.



Three case studies

The Duchess's baby

CircleCI

Rebinding and command injection.
Two vulns chained to RCE.

CVE-2026-95855, CVE-2026-95856

The Jack of Hearts

Docker Hub

Rebinding to credential abuse.
The server acts as you.

GHSA-j65h-q28x-6rhf

Tweedledum and Tweedledee

mcp-go

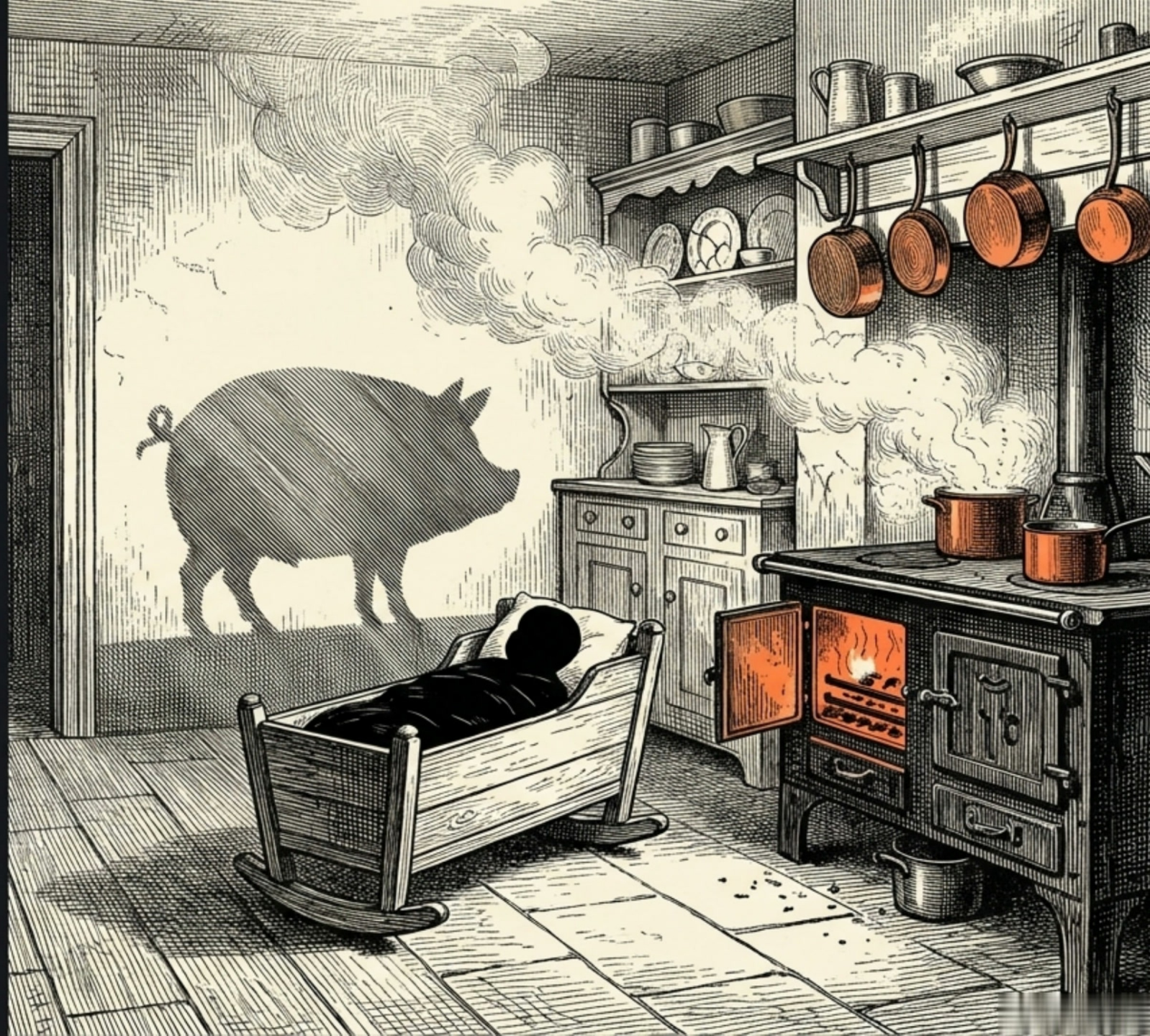
One unsafe SDK default,
inherited by many.

CVE-2026-81092

This time there could be no mistake about it: it was neither more nor less than a pig.

Lewis Carroll, Alice's Adventures in Wonderland, 1865

A file name goes in. A command comes out.



Rebinding into the local server

- The server holds the developer's CircleCI token
- A malicious page rebinds and talks to it as `localhost`
- 17 tools exposed: drive the victim's CI/CD, no auth
- Run pipelines, rerun workflows, roll back deployments

`CVE-2026-95855` `GHSA-jwj7-74jh-p5c4` `CVSS 3.1 8.3`

Fixed in @circleci/mcp-server-circleci 0.17.0 with Host and Origin validation

DEMO 1

Chaining the two: rebind → RCE

CVE-2026-95855 + CVE-2026-95856

CircleCI said thanks

Attacker dashboard Step 8 of 8

Same list, same channel: run_evaluation_tests takes a filename.

CASE STUDY 1 · CIRCLECI

In the end, the shell decides what the name means

The demo stopped at a read-only call. **run_evaluation_tests** is on the same channel, and it writes each prompt file with this line:

```
… | sudo tee /prompts/${file.fileName} > /dev/null
```

With the filename we supply, the CI runner executes:

```
… | sudo tee /prompts/bedtime.prompt.yml; echo HELLO_TLV; # > /dev/null
```

The **#** comments out the rest of the line. The same name also lands in **python eval.py ${file.fileName}**, and that config is sent to CircleCI, so it runs in the runner with the pipeline's secrets.

The failure is the moment a label becomes executable text.

CVE-2026-95856 · GHSA-m9x7-h9px-p447 · CVSS 3.1 10.0 · fixed in 0.16.1

“The Jack of Hearts, he stole those tarts, and took them quite away!”

Lewis Carroll, Alice’s Adventures in Wonderland, 1865

The server holds the keys, and spends them for whoever asks.

The server spends your credentials for you

Attacker's JavaScript
In the victim's browser tab. Has no token.

→

`hub-mcp` on `localhost`
Holds the victim's Docker Hub PAT.

→

Docker Hub API
Sees a normal request from the victim.

Enumerate private namespaces, organizations and repository metadata

Call **`createRepository`** and **`updateRepositoryInfo`** as the victim

The token never reaches attacker JS, and it doesn't need to

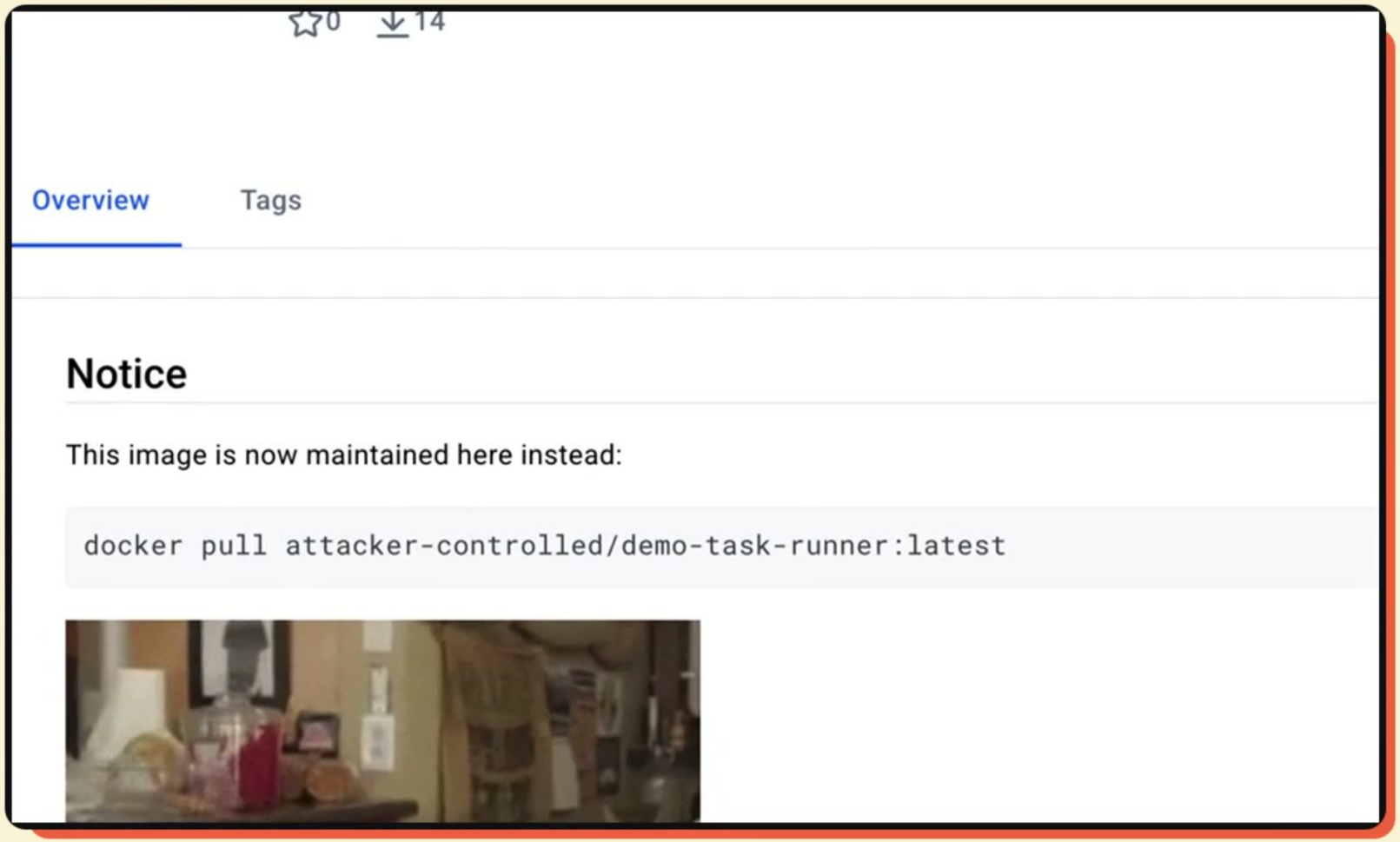
`GHSA-j65h-q28x-6rhf CVSS 4.0 8.3 High`

Affects `--transport=http`, 0.1.0 to 0.18.0. Fixed in 0.19.0.
The default stdio mode is not affected.

DEMO 2

Docker Hub: use the victim’s credentials

GHSA-j65h-q28x-6rhf



Docker Hub Step 7 of 7

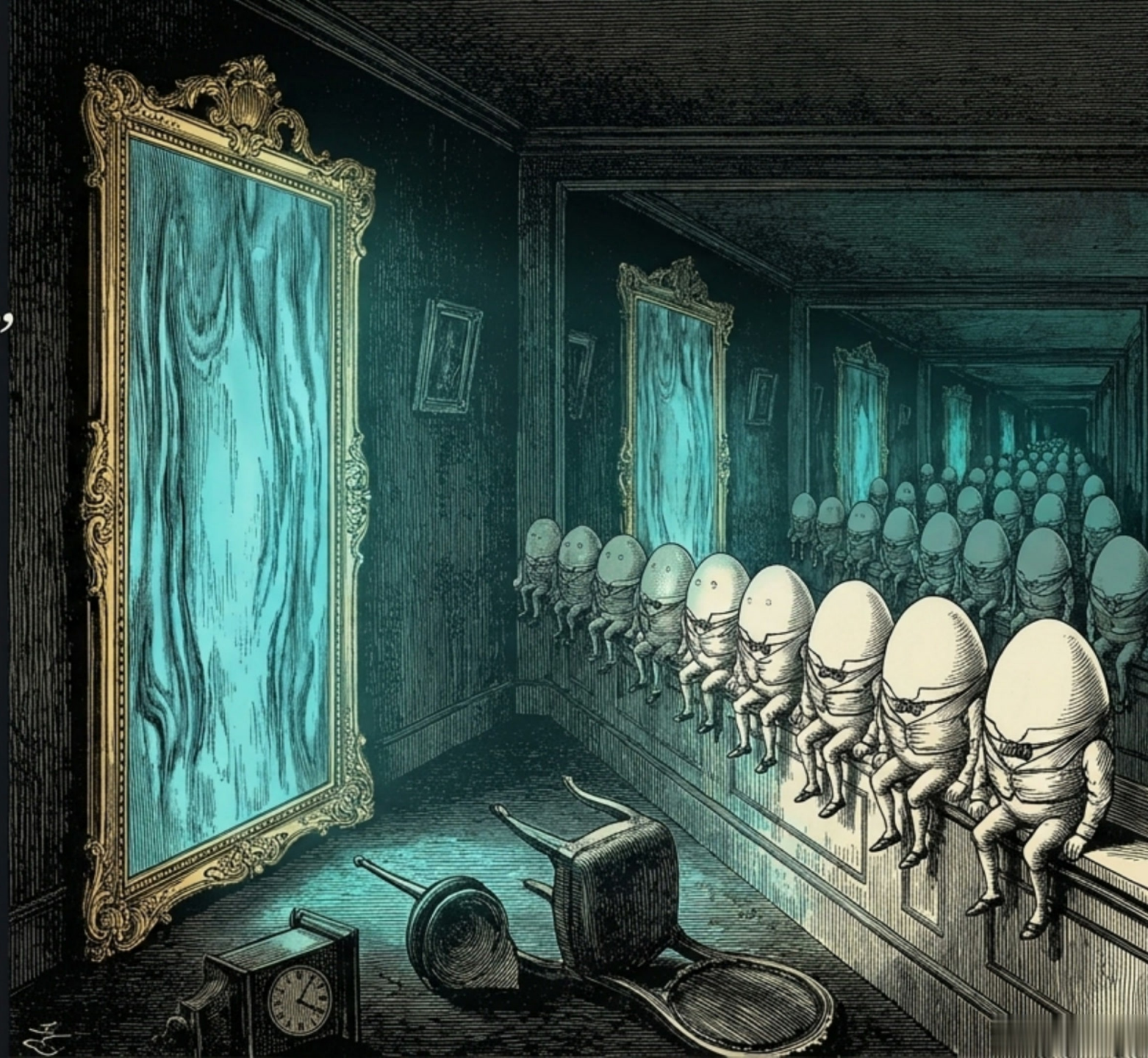
Anyone who visits now reads a different pull command.

```
docker pull attacker-controlled/
  demo-task-runner:latest
```

“When I use a word, it means just what I choose it to mean, neither more nor less.”

Humpty Dumpty, Through the Looking-Glass, 1871

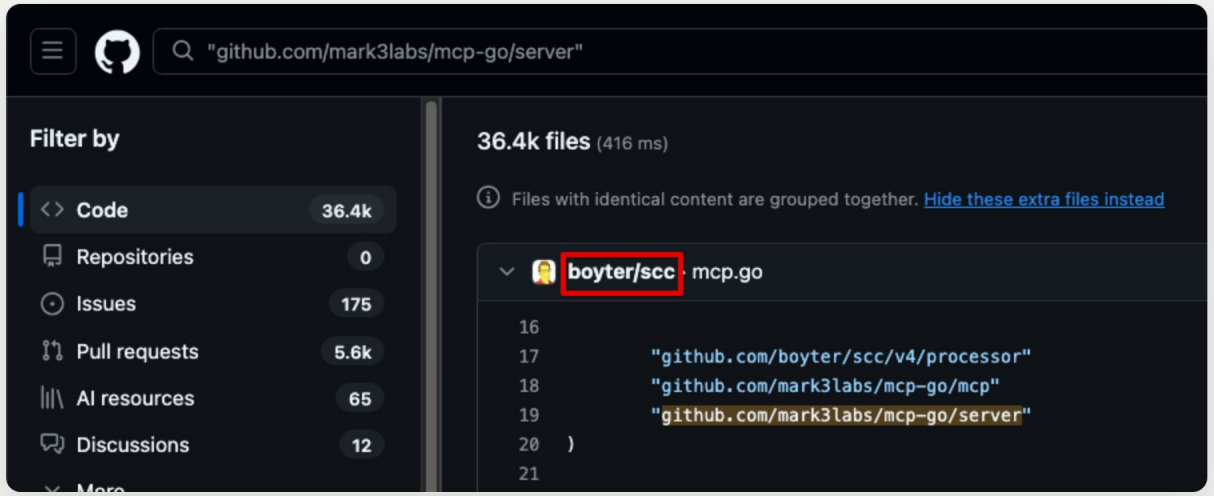
To the server, a `Host` header means whatever the attacker says it means.



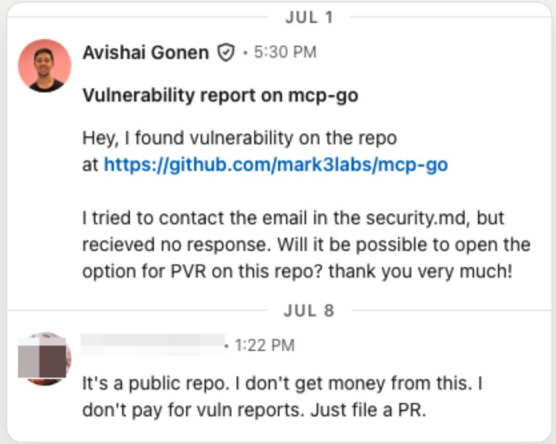
THE SDK ANGLE

One unsafe default, everywhere

mark3labs/mcp-go shipped with no Host or Origin check. CVE-2026-81092 · CVSS 4.0 7.6



36.4k files on GitHub import mcp-go's server package.



Asking for a private way to report it.

Fixed in 0.56.0: new server/http_localhost.go rejects loopback requests that name a non-loopback host.

“Off with their headers!”

The Queen of Hearts, more or less

Zero trust for `localhost`:
check the **`Host`**,
check the **`Origin`**,
demand a token.

DNS REBINDING

The fixes that work

1 · Validate Host

Accept only localhost, 127.0.0.1 and [::1] on your port. After a rebind the request says **Host: attacker.com**. Reject it.

2 · Validate Origin

Reject browser requests from an Origin you don't expect. The rebinding page sends its own: **http://attacker.com**.

3 · Require auth

A per-install token the webpage can't know. **Local is not a credential.**

Why CORS doesn't help

After the rebind, the page and the "server" share one origin: attacker.com. The browser sees a same-origin request, so CORS is never asked.

The MCP spec already says it: *"Servers **MUST** validate the Origin header on all incoming connections to prevent DNS rebinding attacks."*

“You’re nothing but a pack of cards!”

DNS rebinding is the new door. What’s behind it is decades old.

Bug class	Behind an MCP server	Example
Command injection	Builds a shell command from caller input	CircleCI: run_evaluation_tests (CVSS 10.0)
SSRF	Sends requests to a URL the caller controls	mcp-atlassian: X-Atlassian-Jira-Url header (CVE-2026-27826)
Path traversal	Writes to a path the caller supplies	mcp-atlassian: confluence_download_attachment (CVE-2026-27825)
Missing auth	Exposes powerful tools to anyone who connects	nginx-ui: /mcp_message (CVE-2026-33032, exploited in the wild)

Unauthenticated tools reach file systems, cloud APIs, CI runners and even physical devices. Forgotten MCP servers make it worse: nobody knows what’s running, what it can reach, or whether anyone reviewed it.

ONE LAST THING

Secure your MCP servers like production

Treat every local MCP server as external attack surface.

It wasn't a dream. It's your localhost.

Avishai Gonen

Yotam Perkal

Slides, demos & write-ups